48시간의 랜섬웨어 대응,
우리에게 주어진 정답 없는 선택의 기로

—

플레인비트 장원희 팀장

YOUR TRUSTED DFIR PARTNER

PLAINBIT

YOUR FILES ARE ENCRYPTED!

Your personal files, documents, photos, databases and other important files have been encrypted!

What happened?

Your files are encrypted with strong encryption algorithm.
There is no way to restore your files without our decryption tool.

How to recover my files?

You can buy our special decryption tool and restore all your files.

Payment method

The only way to recover your files is to pay us.
We only accept cryptocurrency payments.

What happens if I don't pay?

If you don't pay within the time limit:
- Your files will be permanently lost.
- Your data may be published.
- You may be targeted again.

TIME LEFT

47:59:45

Your files will be lost forever!

PAY TO RECOVER FILES

0.50000000 BTC

(≈ 27,500 USD)

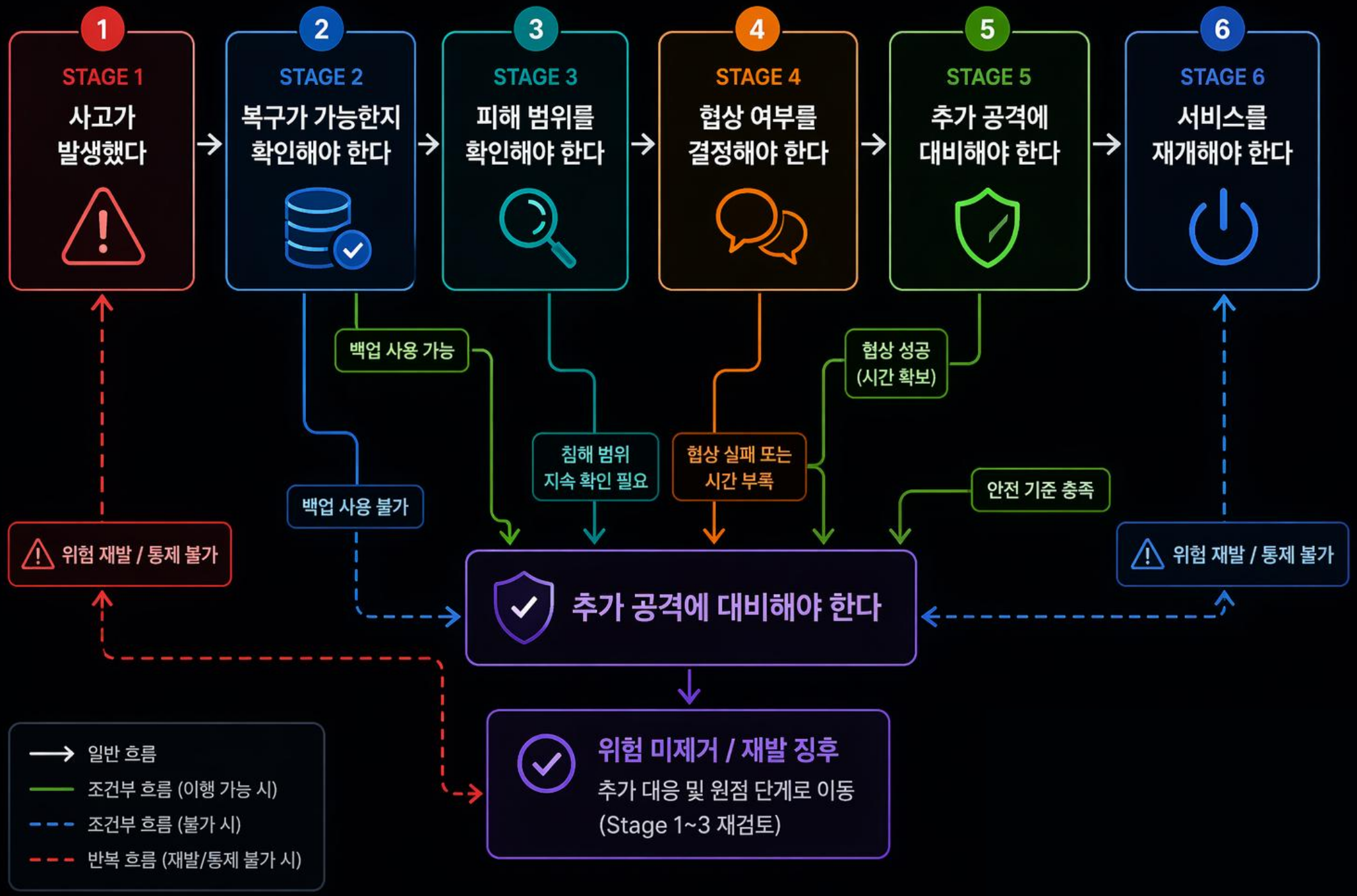
Send the payment to the following address:

bc1qxy2kgdygjrsqtzq2n0yrf2493p83kkfjhx0wlh

COPY ADDRESS

Do not try to modify, rename, or recover your files. It may result in permanent data loss.

48시간 카운트다운, 골든타임의 시작


1
STAGE 1
사고가 발생했다
2
STAGE 2
복구가 가능한지 확인해야 한다
3
STAGE 3
피해 범위를 확인해야 한다
4
STAGE 4
협상 여부를 결정해야 한다
5
STAGE 5
추가 공격에 대비해야 한다
6
STAGE 6
서비스를 재개해야 한다
백업 사용 가능
백업 사용 불가
침해 범위 지속 확인 필요
협상 실패 또는 시간 부록
협상 성공 (시간 확보)
안전 기준 충족
위험 재발 / 통제 불가
위험 재발 / 통제 불가
추가 공격에 대비해야 한다
위험 미제거 / 재발 징후
추가 대응 및 원점 단계로 이동 (Stage 1~3 재검토)
일반 흐름
조건부 흐름 (이행 가능 시)
조건부 흐름 (불가 시)
반복 흐름 (재발/통제 불가 시)

48:00

지금 무엇부터 해야 하는가?

성급 하지 않는 상태에서 상황을 이해하는 것이 중요했다

STAGE 1. 사고가 발생했다

48:00

- 랜섬웨어 감염은 언제 시작된 것인가?
- 핵심 서비스 또는 주요 서버가 감염되었는가?
- 감염된 시스템의 네트워크를 즉시 격리해야 하는가?
- 공격이 현재도 진행 중인가?

시스템이 아니라, 공격자를 무력화하기 위해 상황 통제를 위한 준비를 시작했다

STAGE 2. 복구가 가능한지 확인해야 한다

36:00

우리는 정말 복구를 할 수 있는 상태인가?

복구는 검증이 필요했다

36:00

STAGE 2. 복구가 가능한지 확인해야 한다

- 백업 서버가 감염되었는가?
- 가장 최근 백업본은 언제 생성된 것인가?
- 백업 데이터가 이미 공격자의 영향을 받은 것은 아닌가?
- 백업으로 복구하면 동일한 공격이 재발되지 않는가?

안전한 백업으로 복구할 수 있는 상태인지가 더 중요했다

STAGE 3. 피해 범위를 확인해야 한다

24:00

파일만 암호화된 것인가, 이미 데이터가 유출된 것인가?

직면한 문제를 정확하게 알아야 한다

24:00

STAGE 3. 피해 범위를 확인해야 한다

- 우리가 아직 발견하지 못한 시스템이 추가로 존재하는가?
- 공격자가 중앙 관리형 서버 등에 침투한 정황은 없는가?
- 관리자 계정 또는 주요 계정이 이미 침해된 상태인가?
- 정보 유출이 발생했을 가능성은 없는가?

사고에 대한 전파 경로를 식별해 보이지 않는 침해를 파악하고, 추가 공격에 대한 대응을 준비했다

STAGE 4. 협상 여부를 결정해야 한다

12:00

협상을 하지 않고 버틸 수 있는가?

협상은 기술이 아니라 전략이다

STAGE 4. 협상 여부를 결정해야 한다

12:00

- 협상 비용이 암호화된 데이터의 가치보다 합리적인가?
- 정보 유출에 대한 협상 대응은 어떻게 할 것인가?
- 협상은 누가 할 것인가?
- 협상 시 공격은 중단되는가?

사고 대응 시간을 확보하기 위한 전략적 도구로 협상을 활용했다

STAGE 5. 추가 공격에 대비해야 한다

05:00

공격자는 아직 내부에 남아 있는가?

공격은 아직 끝나지 않았다

STAGE 5. 추가 공격에 대비해야 한다

05:00

- 침입 경로와 내부 전파 경로가 통제된 상태인가?
- 공격자가 여전히 시스템을 실시간으로 제어할 수 있는 상태인가?
- 지금까지 조치한 대응이 공격자에게 이미 노출된 상태는 아닌가?
- 공격이 재발되면 즉시 탐지하고 대응할 수 있는 상태인가?

완벽한 차단이 아니라, 공격이 다시 시작되면 바로 잡을 수 있는 환경을 만들었다

00:00

서비스 재개, 지금이 적합한가?

위협이 침해로 이어지는 과정을 무력화해야 한다

STAGE 6. 서비스를 재개해야 한다

00:00

- 발생한 사고와 관련된 위협이 잔존해 있지는 않는가?
- 동일한 공격이 재발할 가능성은 없는가?
- 비즈니스 연속성을 유지할 수 있을 만큼 위험이 통제된 상태인가?
- 호스트나 네트워크에서 발생하는 위협에 대해 가시성이 확보된 상태인가?

완벽한 안전이 아니라, 대응할 수 있는 상태에서 서비스를 재개했다

직면한 주요 챌린지에 대한 DEFENDER의 선택

사고는 공격자가 통제하지만, 시간을 벌기 위한 대응을 선택했다

우리는 준비된 시점에 한 번에 더 큰 피해를 막는 대응을 선택했다

공격자에게 챌린지를 주는 대응 방식을 선택했다

모든 선택에는 리스크가 따른다.
우리는 완벽함이 아니라 통제를 선택했다.
YOUR TRUSTED DFIR PARTNER
PLAINBIT